23CB402 CYBER SECURITY

UNIT I INTRODUCTION

Cyber Security – History of Internet – Impact of Internet – CIA Triad; Reason for Cyber Crime – Need for Cyber Security – History of Cyber Crime; Cybercriminals – Classification of Cybercrimes – A Global Perspective on Cyber Crimes; Cyber Laws – The Indian IT Act – Cybercrime and Punishment.

1.1 Cyber Security

1.1.1 Definition

The technique of protecting internet-connected systems such as computers, servers, mobile devices, electronic systems, networks, and data from malicious attacks is known as cybersecurity. We can divide cybersecurity into two parts one is cyber, and the other is security. Cyber refers to the technology that includes systems, networks, programs, and data. And security is concerned with the protection of systems, networks, applications, and information. In some cases, it is also called **electronic information security** or **information technology security**.

1.1.2 **Types of Cyber Security**

Every organization's assets are the combinations of a variety of different systems. These systems have a strong cybersecurity posture that requires coordinated efforts across all of its systems. Therefore, we can categorize cybersecurity in the following sub-domains:

- **Network Security:** It involves implementing the hardware and software to secure a computer network from unauthorized access, intruders, attacks, disruption, and misuse. This security helps an organization to protect its assets against external and internal threats.
- **Application Security:** It involves protecting the software and devices from unwanted threats. This protection can be done by constantly updating the apps to ensure they are secure from attacks. Successful security begins in the design stage, writing source code, validation, threat modeling, etc., before a program or device is deployed.
- **Information or Data Security:** It involves implementing a strong data storage mechanism to maintain the integrity and privacy of data, both in storage and in transit.
- **Identity management:** It deals with the procedure for determining the level of access that each individual has within an organization.
- **Operational Security:** It involves processing and making decisions on handling and securing data assets.
- **Mobile Security:** It involves securing the organizational and personal data stored on mobile devices such as cell phones, computers, tablets, and other similar devices against various malicious threats. These threats are unauthorized access, device loss or theft, malware, etc.
- **Cloud Security:** It involves in protecting the information stored in the digital environment or cloud architectures for the organization. It uses various cloud service providers such as AWS, Azure, Google, etc., to ensure security against multiple threats.

- **Disaster Recovery and Business Continuity Planning:** It deals with the processes, monitoring, alerts, and plans to how an organization responds when any malicious activity is causing the loss of operations or data. Its policies dictate resuming the lost operations after any disaster happens to the same operating capacity as before the event.
- **User Education:** It deals with the processes, monitoring, alerts, and plans to how an organization responds when any malicious activity is causing the loss of operations or data. Its policies dictate resuming the lost operations after any disaster happens to the same operating capacity as before the event.

1.1.3 The start of cybersecurity

Cybersecurity history is interesting indeed. It is thought to have started in 1971 when Bob Thomas, a computer programmer with BBN, created and deployed a virus that served as a security test. It was not malicious but did highlight areas of vulnerability and security flaws in what would become "the internet."

The virus, named after a Scooby Doo villain, "Creeper," was designed to move across ARPANET (Advanced Research Projects Agency Network) – the forerunner to what we now call the internet. ARPANET was established by the U.S. Department of Defense.

Thomas created the computer worm to be a non-harmful self-replicating experimental program. It was intended to illustrate how mobile applications work, but instead, it corrupted the DEC PDP-10 mainframe computers at the Digital Equipment Corporation, interfering with the teletype computer screens which were connected. All the users could see on the screen were the words "I'm the creeper, catch me if you can!"

In response, Ray Tomlinson, Thomas' colleague created the Reaper Program. It was similar to the Creeper. It moves through the internet, replicating itself, and finds copies of the Creeper. When it locates the copies, it logs them out, so they are rendered impotent. The Reaper was the first attempt at cybersecurity – the first antivirus software program.

1.2 History of the Internet

Initially in the 1960s, the **Internet was started** as a medium for sharing information with government researchers. During the time computers were larger in size and were immovable. In case anyone had to access the information stored in any computer, they had to travel to the location of the computer or the other way to have magnetic computer tapes that could be transported through the postal system of that time.

Alongside, Escalated Cold War played a major role in the **creation of the internet**. The Soviet Union had deployed the Sputnik satellite which led the Defense Department of the United States to examine the possibilities of communicating information despite nuclear. The situation resulted in the development of **ARPANET** (Advanced Research Projects Agency Network), which, later on, **evolved into the Internet**. In the initial days, ARPANET became a huge success with restricted participation where it was accessible to academic and research institutions that had contracts with the US Defense

Department. The scenario led to the formation of new networks in order to facilitate the need for information sharing with other people.

Earlier there wasn't any standard mechanism for the computer networks that would enable them to communicate with each other. Transfer Control Protocol (TCP/IP) which was developed in 1970, was adopted as a new communication protocol for ARPANET in 1983. The technology enabled various computers on different networks to communicate with each other and this is **how the Internet was officially born** on January 1, 1983.

1.2.1 An Overview From 1985 to 1995

The **invention of DNS**, the widespread usage of TCP/IP, and the **popularity of email** all contributed to an increase in internet activity. Between 1986 and 1987, the network expanded from 2,000 to 30,000 hosts. People were increasingly **using the internet** to send messages, read news, and exchange files. However, sophisticated computing knowledge was still required to dial into the system and use it efficiently, and there was still no agreement on how documents on the network should be formatted.

The internet needed to be more user-friendly. In 1989, **Tim Berners-Lee**, a British computer scientist, proposed a solution to his employer, CERN, the international particle-research facility in Geneva, Switzerland. He proposed a new method for organizing and connecting all of the information available on CERN's computer network, making it quick and easy to access. His idea for a "network of information" evolved into the World Wide Web.

The release of the Mosaic browser in 1993 introduced the web to a new non-academic audience, and people began to learn how simple it was to make their own HTML websites. As a result, the number of websites increased from 130 in 1993 to over 100,000 at the beginning of 1996.

By 1995, **the internet and the World Wide Web** had become an established phenomenon, with over 10 million global users using the Netscape Navigator. The Netscape Navigator was the most popular browser at that point in time.

1.2.2 What is DNS?

DNS is short for **Domain Name System**. It functions as the internet's version of a phone book, converting difficult-to-remember IP addresses into simple names. Cheaper technology and the introduction of desktop computers in the early 1980s facilitated the rapid development of local area networks (LANs). As the number of machines on the network grew, it became impossible to keep track of all the different IP addresses.

The **development of the Domain Name System (DNS)** in 1983 solved this problem. DNS was invented at the University of Southern California by Paul Mockapetris and Jon Postel. It was one of the breakthrough inventions that helped in paving the way for the World Wide Web.

TCP/IP or Transmission Control Protocol / Internet Protocol

TCP/IP is an acronym that stands for Transmission Control Protocol / Internet Protocol. The terms refer to a set of protocols that regulate how data flows via a network.

Following the **development of ARPANET**, new computer networks began to join the network, prompting the need for an agreed-upon set of data-handling standards. Bob Kahn and Vint Cerf, two American computer scientists, in the year 1974 invented a new way of transmitting data packets in a digital envelope known as 'Datagram'. Any computer can read the datagram's address, but only the ultimate host system can open the envelope and read the message within.

This technology was dubbed the transmission-control protocol by Kahn and Cerf. TCP enabled computers to communicate in the same language, allowing the ARPANET to evolve into a global interconnected network of networks, an example of 'internetworking'—written as the "internet" in short.

IP stands for Internet Protocol and when paired with TCP, aids in the routing of internet data. Every internet-connected device is assigned a unique IP address. The number, known as an IP address, can be used to find out the location of any internet-connected device.

1.3 Impact of Internet

The internet has had an incredible impact on society since its inception. It has changed the way we communicate, do business, learn, and even think. The internet has brought people from different parts of the world together and has made information accessible to everyone with an internet connection.

One of the biggest impacts of the internet is on communication. Social media platforms like Facebook, Twitter, and Instagram have made it easy for people to connect with others from anywhere in the world. People can share their thoughts, ideas, and experiences instantly with their friends and family. Video conferencing tools like Zoom have revolutionized remote communication, making it possible for people to work and learn from anywhere in the world.

The internet has also had a significant impact on business. E-commerce websites like Amazon and eBay have made it possible for people to shop from the comfort of their own homes. Small businesses can now reach a global audience by creating an online presence. The internet has also made it easier for people to work from home, which has become increasingly important during the COVID-19 pandemic.

Education is another area that has been greatly impacted by the internet. Online courses and tutorials have made it possible for people to learn new skills from anywhere in the world. Massive open online courses (MOOCs) like Coursera and edX have made higher education more accessible to people who may not have the opportunity to attend a traditional university.

However, the internet has also had some negative impacts. Cyberbullying, online harassment, and identity theft have become increasingly common. The internet has also made it easier for people to access inappropriate content, which can have a negative impact on young children.

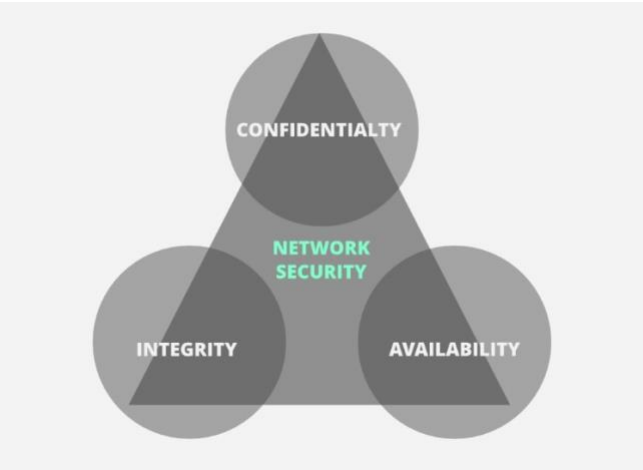
In conclusion, the internet has had a tremendous impact on society. It has changed the way we communicate, do business, learn, and even think. While there are some negative impacts, the benefits of the internet far outweigh the negatives. As the internet continues to evolve, it will be interesting to see how it will shape our society in the future.

1.4 CIA Triad

When talking about network security, the **CIA** triad is one of the most important models which is designed to guide policies for information security within an organization.

CIA stands for :

1. Confidentiality
2. Integrity
3. Availability



These are the objectives that should be kept in mind while securing a network.

1.4.1 Confidentiality

Confidentiality is about preventing the disclosure of data to unauthorized parties.

It also means trying to keep the identity of authorized parties involved in sharing and holding data private and anonymous.

Often confidentiality is compromised by cracking poorly encrypted data, Man-in-the-middle (MITM) attacks, disclosing sensitive data.
Standard measures to establish confidentiality include:
• Data encryption
• Two-factor authentication
• Biometric verification
• Security tokens

Confidentiality means that only authorized individuals/systems can view sensitive or classified information. The data being sent over the network should not be accessed by unauthorized individuals. The attacker may try to capture the data using different tools available on the Internet and gain access to your information. A primary way to avoid this is to use encryption techniques to safeguard your data so that even if the attacker gains access to your data, he/she will not be able to decrypt it. Encryption standards include **AES**(Advanced Encryption Standard) and **DES** (Data Encryption Standard). Another way to protect your data is through a VPN tunnel. VPN stands for Virtual Private Network and helps the data to move securely over the network.

1.4.2 Integrity

Integrity refers to protecting information from being modified by unauthorized parties.
Standard measures to guarantee integrity include:
• Cryptographic checksums
• Using file permissions
• Uninterrupted power supplies
• Data backups

Corruption of data is a failure to maintain data integrity. To check if our data has been modified or not, we make use of a hash function.
We have two common types: SHA (Secure Hash Algorithm) and MD5(Message Direct 5).

MD5 is a 128-bit hash and SHA is a 160-bit hash if we're using SHA-1. There are also other SHA methods that we could use like SHA-0, SHA-2, and SHA-3.

Let's assume Host 'A' wants to send data to Host 'B' to maintain integrity. A hash function will run over the data and produce an arbitrary hash value **H1** which is then attached to the data. When Host 'B' receives the packet, it runs the same hash function over the data which gives a hash value of **H2**. Now, if **H1 = H2**, this means that the data's integrity has been maintained and the contents were not modified.

1.4.3 Availability

Availability is making sure that authorized parties are able to access the information when needed.
Standard measures to guarantee availability include:
• Backing up data to external drives
• Implementing firewalls
• Having backup power supplies
• Data redundancy

Availability means that the network should be readily available to its users. This applies to systems and to data. To ensure availability, the network administrator should maintain hardware, make regular upgrades, have a plan for fail-over, and prevent bottlenecks in a network. Attacks such as DoS or DDoS may render a network unavailable as the resources of the network get exhausted. The impact may be significant to the companies and users who rely on the network as a business tool. Thus, proper measures should be taken to prevent such attacks.

Cyber attacks

A cyberattack is a malicious and deliberate attempt by an individual or organization to breach the information system of another individual or organization.
A cyberattack is an intentional attempt to access a computer system, network, or digital device to steal, alter, disable, expose, or destroy data, applications, or other assets. Cyberattacks can be motivated by a variety of reasons, including petty theft and acts of war

Types of Cyber Attacks

A cyber-attack is an exploitation of computer systems and networks. It uses malicious code to alter computer code, logic or data and lead to cybercrimes, such as information and identity theft.

Cyber-attacks can be classified into the following categories:

1) Web-based attacks
2) System-based attacks

Web-based attacks
These are the attacks which occur on a website or web applications. Some of the important web-based attacks are as follows-

1. Injection attacks
It is the attack in which some data will be injected into a web application to manipulate the application and fetch the required information.
Example- SQL Injection, code Injection, log Injection, XML Injection etc.
2. DNS Spoofing
DNS Spoofing is a type of computer security hacking. Whereby a data is introduced into a DNS resolver's cache causing the name server to return an incorrect IP address, diverting traffic to the attackers computer or any other computer. The DNS spoofing attacks can go on for a long period of time without being detected and can cause serious security issues.
3. Session Hijacking
It is a security attack on a user session over a protected network. Web applications create cookies to store the state and user sessions. By stealing the cookies, an attacker can have access to all of the user data.
4. Phishing
Phishing is a type of attack which attempts to steal sensitive information like user login credentials and credit card number. It occurs when an attacker is masquerading as a trustworthy entity in electronic communication.
5. Brute force
It is a type of attack which uses a trial and error method. This attack generates a large number of guesses and validates them to obtain actual data like user password and personal identification number. This attack may be used by criminals to crack encrypted data, or by security, analysts to test an organization's network security.

6. Denial of Service

It is an attack which meant to make a server or network resource unavailable to the users. It accomplishes this by flooding the target with traffic or sending it information that triggers a crash. It uses the single system and single internet connection to attack a server. It can be classified into the following-

Volume-based attacks- Its goal is to saturate the bandwidth of the attacked site, and is measured in bit per second.
Protocol attacks- It consumes actual server resources, and is measured in a packet.
Application layer attacks- Its goal is to crash the web server and is measured in request per second.
7. Dictionary attacks
This type of attack stored the list of a commonly used password and validated them to get original password.
8. URL Interpretation

It is a type of attack where we can change the certain parts of a URL, and one can make a web server to deliver web pages for which he is not authorized to browse.

9. File Inclusion attacks

It is a type of attack that allows an attacker to access unauthorized or essential files which is available on the web server or to execute malicious files on the web server by making use of the include functionality.

10. Man in the middle attacks

It is a type of attack that allows an attacker to intercepts the connection between client and server and acts as a bridge between them. Due to this, an attacker will be able to read, insert and modify the data in the intercepted connection.

System-based attacks

These are the attacks which are intended to compromise a computer or a computer network. Some of the important system-based attacks are as follows-

1. Virus

It is a type of malicious software program that spread throughout the computer files without the knowledge of a user. It is a self-replicating malicious computer program that replicates by inserting copies of itself into other computer programs when executed. It can also execute instructions that cause harm to the system.

2. Worm

It is a type of malware whose primary function is to replicate itself to spread to uninfected computers. It works same as the computer virus. Worms often originate from email attachments that appear to be from trusted senders.

3. Trojan horse

It is a malicious program that occurs unexpected changes to computer setting and unusual activity, even when the computer should be idle. It misleads the user of its true intent. It appears to be a normal application but when opened/executed some malicious code will run in the background.

4. Backdoors

It is a method that bypasses the normal authentication process. A developer may create a backdoor so that an application or operating system can be accessed for troubleshooting or other purposes.

5. Bots

A bot (short for "robot") is an automated process that interacts with other network services. Some bots program run automatically, while others only execute commands when they receive specific input. Common examples of bots program are the crawler, chatroom bots, and malicious bots.

1.5 Reasons behind cyber crime

Definition

Cybercrime is any criminal activity that involves a computer, network or networked device. While most cybercriminals use cybercrimes to generate a profit, some cybercrimes are carried out against computers or devices to directly damage or disable them.

Reasons behind cyber crime

Every business, regardless of its size, is a potential target of cyber attack. That is because every business has key assets (financial or otherwise) that criminals may seek to exploit. By recognising the common motives behind cyber attacks, you can build a better understanding

of the risks you may face, and understand how best to confront them.

Why do cyber attacks happen?

Most often, cyber attacks happen because criminals want your:

- business' financial details
- customers' financial details (eg credit card data)
- sensitive personal data
- customers' or staff email addresses and login credentials
- customer databases
- clients lists
- IT infrastructure
- IT services (eg the ability to accept online payments)
- intellectual property (eg trade secrets or product designs)

Cyber attacks against businesses are often deliberate and motivated by financial gain. However, other motivations may include:

- making a social or political point - eg through hacktivism
- espionage - eg spying on competitors for unfair advantage
- intellectual challenge - eg 'white hat' hacking

The key point is that cyber security threats don't always come from anonymous hackers or online criminal groups. Vulnerabilities can arise within your own business too.

1.5.1 Motivation of cyber criminals

Financial Gain

The primary motivation of a hacker is money, and getting it can be done with a variety of methods.

They could directly gain entry to a bank or investment account; steal a password to your financial sites and then transfer the assets over to one of their own; swindle an employee into completing a money transfer through a complicated spear phishing technique, or conduct a ransomware attack on your entire organization.

The possibilities are endless, but most hackers are out to make a profit.

1. Recognition & Achievement

Some hackers are motivated by the sense of achievement that comes with cracking open a major system. Some may work in groups or independently, but, on some scale, they would like to be recognized.

This also ties into the fact that cyber criminals are competitive by nature, and they love the challenge their actions bring. In fact, they often drive one another to complete more

complicated hacks.

2. Insider Threats

Individuals who have access to critical information or systems can easily choose to misuse that access
—to the detriment of their organization.

These threats can come from internal employees, vendors, a contractor or a partner—and are viewed as some of the greatest cyber security threats to organizations.

However, not all insider threats are intentional, according to an Insider Threat Report from Crowd Research Partners. Most (51%) are due to carelessness, negligence, or compromised credentials, but the potential impact is still present even in an unintentional scenario.

3. Political Motivation – "Hacktivism"

Some cyber criminal groups use their hacking skills to go after large organizations. They are usually motivated by a cause of some sort, such as highlighting human rights or alerting a large corporation to their system vulnerabilities. Or, they may go up against groups whose ideologies do not align with their own.

These groups can steal information and argue that they are practicing free speech, but more often than not, these groups will employ a DDoS (Distributed Denial of Service) attack to overload a website with too much traffic and cause it to crash.

4. State Actors

State-sponsored actors receive funding and assistance from a nation-state. They are specifically engaged in cyber crime to further their nation's own interests. Typically, they steal information, including "intellectual property, personally identifying information, and money to fund or further espionage and exploitation causes."

However, some state-sponsored actors do conduct damaging cyberattacks and claim that their cyberespionage actions are legitimate activity on behalf of the state.

5. Corporate Espionage

This is a form of cyber attack used to gain an advantage over a competing organization. Conducted for commercial or financial purposes, corporate espionage involves:

- Acquiring property like processes or techniques, locations, customer data, pricing, sales, research, bids, or strategies
- Theft of trade secrets, bribery, blackmail, or surveillance.

1.6 Need for cyber crime

Cyber crime is a broad category of malicious activities that can be motivated by a variety of reasons, including:

1.6.1 Protecting Sensitive Data:

With the increase in digitalization, data is becoming more and more valuable. Cybersecurity

helps protect sensitive data such as personal information, financial data, and intellectual property from unauthorized access and theft.

1.6.2 Prevention of Cyber Attacks:

Cyber attacks, such as Malware infections, Ransomware, Phishing, and Distributed Denial of Service (DDoS) attacks, can cause significant disruptions to businesses and individuals. Effective cybersecurity measures help prevent these attacks, reducing the risk of data breaches, financial losses, and operational disruptions.

1.6.3 Safeguarding Critical Infrastructure:

Critical infrastructure, including power grids, transportation systems, healthcare systems, and communication networks, heavily relies on interconnected computer systems. Protecting these systems from cyber threats is crucial to ensure the smooth functioning of essential services and prevent potential disruptions that could impact public safety and national security.

1.6.4 Maintaining Business Continuity:

Cyber attacks can cause significant disruption to businesses, resulting in lost revenue, damage to reputation, and in some cases, even shutting down the business. Cybersecurity helps ensure business continuity by preventing or minimizing the impact of cyber attacks.

1.6.5 Compliance with Regulations:

Many industries are subject to strict regulations that require organizations to protect sensitive data. Failure to comply with these regulations can result in significant fines and legal action. Cybersecurity helps ensure compliance with regulations such as HIPAA, GDPR, and PCI DSS.

1.6.6 Protecting National Security:

Cyber attacks can be used to compromise national security by targeting critical infrastructure, government systems, and military installations. Cybersecurity is critical for protecting national security and preventing cyber warfare.

1.6.7 Preserving Privacy:

In an era where personal information is increasingly collected, stored, and shared digitally, cybersecurity is crucial for preserving privacy. Protecting personal data from unauthorized access, surveillance, and misuse helps maintain individuals' privacy rights and fosters trust in digital services.

1.7 History of cyber crimes

Technically, the first cyber attack happened in France well before the internet was even invented, in 1834. Attackers stole financial market information by accessing the French telegraph system. Still, cybercrime didn't really find its footing until the late 20th century. Spurred on by the digital revolution, cybercriminals became early adopters of technology,

using their head start and their smarts to engineer new, devious ways to part people and organizations from their data and dollars. From that moment on, cybercrime has grown exponentially, marked by an evolution of tactics, techniques, and procedures (TTPs) — all implemented for malicious gain.

Now, cybercrime has expanded into its own ecosystem, full of leak sites, "as-a-service" models, lucrative attack vectors such as business email compromise (BEC), and an expanding global footprint that costs organizations more and more every year.

If there was a cybercrime hall of infamy, its halls would be lined with the names and faces of these noted attacks and attackers whose "groundbreaking" work caught both the eye of federal investigators and the envy of fellow hackers.

1962
The modern history of cybercrime began when Allen Scherr launched a cyber attack against the MIT computer networks, stealing passwords from their database via punch card.

1971
The first computer virus was created for research purposes by Bob Thomas at BBN technologies. Referred to as the Creeper Virus, the self-replicating program was detected on the ARPANET in 1971 and foretold the potential of future viruses to cause significant damage to computer systems.

1981
Ian Murphy became the first person ever to be convicted for committing a cybercrime after successfully hacking into AT&T's internal systems and changing their computers' clocks, causing havoc.

1988
The first major cyber attack on the internet came courtesy of Cornell grad student Robert Morris. The "Morris Worm" struck in the year before the World Wide Web debuted, back when the internet was primarily the domain of academic researchers. It infected computer systems at Stanford, Princeton, Johns Hopkins, NASA, Lawrence Livermore Labs, and UC Berkeley, among other institutions.

1989
Ransomware made its first appearance. This first strain of ransomware — the AIDS Trojan — was easy to remove, rendering it ineffective. Unlike the ransomware of today, this one appeared on floppy disks, with the cybercriminal handing out 20,000 infected disks to attendees of the World Health Organization's AIDS conference.
Explore ransomware in-depth.

The 1990s: New Technology Brings New Crime
The decade of the '90s gave rise to some of the greatest communication technologies and changes known to mankind, with the internet connecting people across different communication networks wherever they were, all over the world.

But it wasn't all good news. Cybercrime grew in strength thanks to these advancements. Hackers and bad actors leveraged the fact that, as these new technologies were developed and built, trust and safety controls weren't initially a major concern.

Cybersecurity was a term yet to be coined, let alone an active field, so creating groundbreaking applications for communications and business efficiency was the principal focus of these years. Nevertheless, an underground economy was slowly growing in strength, as viruses started to take hold.

AOL, the leading internet provider of the decade, unwittingly became an attack vector itself, as cybercriminals would steal user credentials, launch phishing attacks, and spam other AOL users through instant messenger or email.
Escalating rates of cybercrime signaled that attackers were enjoying fresh opportunities, and devising new means to gain unauthorized access to systems and manipulate data across the web.

Here's some of the notable cybercrimes of this decade:

1994
Datastream Cowboy and Kuji — a 16-year-old British schoolboy and his accomplice — used a "password sniffer" program to launch a series of attacks that crippled the Air Force's Rome Laboratory, while stealing research data used as attack instructions for warplanes in battle.

1995
Vladimir Levin was the first known hacker to attempt to rob a bank — and a very big bank at that. He hacked into Citibank's network and conducted many fraudulent transactions. All told, he transferred more than 10 million dollars into various bank accounts worldwide.

1995
Kevin Mitnick — one of history's most notorious hackers — became the first person to penetrate large networks by manipulating people and using insiders to get the codes to access Motorola and Nokia, among others.

1998
Max Butler, a security consultant for the FBI among others, hacked into U.S. government websites under false pretenses. The U.S Air Force alerted officials to his misdeeds, and he received an 18-month sentence. Later, for another illicit foray, he was sentenced to 13 years, a record for a hacker.

1999
Computer viruses were relatively unknown by the general public until the Melissa Virus struck in March 1999. A document uploaded online and promising access to adult videos, the virus would take over individual's Microsoft Word applications, then jump to their Microsoft Outlook , and self-propagate by sending itself to various email accounts. It caused an estimated $80 million in damages and was one of the first major viruses that expanded beyond AOL.

The New Millennium: Cybercrime Ramps Up

The first decade of the new millennium saw more sophisticated attacks and an abundance of advanced persistent threat actors (APTs), most of which were sponsored by nation-states. The evolution of cybercrime meant new viruses and worms, which caused significant damage to critical sectors of the global, digital economy.

By decade's end, cybersecurity was a concern to computer users everywhere, but especially to government agencies and large corporations who had the most at stake.

Here's the most notable cybercrimes of the decade:

2000
A 15-year-old hacker named Michael Calse — who went by the online handle “Mafiaboy” — launched a series of distributed denial of service (DDoS) attacks on some of the largest commercial websites in the world, sites like Amazon, Yahoo, CNN, and eBay. The attack brought the sites down for hours in some cases and cost these businesses untold millions.

2000
Another major phishing attack occurred with the ILOVEYOU virus. Sometimes called the LOVEBUG or Love Letter virus, this worm infected over 10 million endpoints across the world. It spread as a spam email, accidentally opened by users, which allowed the worm to gain access to the entire operating system due to a flaw in Windows. It’s estimated that this single attack, which originated with an amateur hacker in the Philippines, caused billions in damages around the globe.

2005
A security breach at a U.S. retailer led to the data leak of 1.4 million HSBC Bank MasterCard users.

2006
The first ransomware strain to use advanced RSA encryption, named Archievus, appears. RSA encryption, or public-key encryption, is now the default for most ransomware attacks.

2008
In one of the largest breaches ever, Heartland Payment systems were attacked using a combination of SQL injection, password sniffers, and malware, compromising the data of 134 million users.

2010s: An Explosion of Cyber Attacks
2010-2020 saw an explosion in cybercrime, turning what was once a cottage industry into a big, global business. Attackers developed new malicious programs and techniques, which increased both the cybercrime rate and the number of attacks per day. Trillions of dollars were lost.

The decade also saw the rise of ransomware, as digital currencies like Bitcoin, the digitizing of organizations, and the proliferation of mobile devices, new operating systems, and the dark web, gave threat actors new avenues and resources for attacks.

Cybercrime wasn’t the only industry that saw huge growth. Organizations began employing more cybersecurity professionals to counter the risk of cyber threats as the sense of assumed digital security dissipated. And, due to the demand for constant data security, a new field emerged known as ethical hacking, whose sole purpose is to discover vulnerabilities prior to malicious exploitation.

The evolution and increased sophistication of different types of cyber threats and how they’re leveraged in attacks puts organizations in precarious positions when it comes to defending against them.

If the 2010s were the decade where cybercrime was finding its footing, the 2020s have seen the ecosystem sophisticate in new ways.
There have been two colliding forces this decade: One is an overall rise in cybercrime driven

by technological advances as well as socioeconomic forces particularly in Eastern Europe and Asia, and the other is the rapid digitization of organizations who are turning to the cloud, individual endpoints, and global expansion, but are doing so faster than their cybersecurity measures can keep up.

The results?

- Cybercrime is now a 1.5 trillion-dollar industry
- Cybercrime is the number one global business risk
- The average cost of a data breach is now $4.45 million USD
- 82% of breaches involve the cloud
- Cybercriminals are frequently targeting healthcare, which is now the top attacked industry
- Phishing and compromised credentials are the top two attack vectors
- Ransomware made up 24% of attacks in 2023

It's clear that cybercrime has evolved rapidly, and while advances in cybersecurity continue to happen, it's a constant battle between overworked, understaffed security departments and threat actors.

The Future of Cybercrime

From viruses on floppy disks to highly organized ransomware gangs evading law enforcement and stealing millions of dollars, cybercrime has come a long way.

The same advanced technology used for cybersecurity — including machine-learning and AI tools — are employed by today's cybercriminals, too. So, staying one step ahead of them is an ongoing challenge.

1.8 Cybercriminals

A cybercriminal is a person who conducts some form of illegal activity using computers or other digital technology such as the Internet. The criminal may use computer expertise, knowledge of human behavior, and a variety of tools and services to achieve his or her goal.

1.8.1 Types of Cyber Criminals:

1. Hackers: The term hacker may refer to anyone with technical skills, however, it typically refers to an individual who uses his or her skills to achieve unauthorized access to systems or networks so as to commit crimes. The intent of the burglary determines the classification of those attackers as white, grey, or black hats. White hat attackers burgled networks or PC systems to get weaknesses so as to boost the protection of those systems. The owners of the system offer permission to perform the burglary, and they receive the results of the take a look at. On the opposite hand, black hat attackers make the most of any vulnerability for embezzled personal, monetary or political gain. Grey hat attackers are somewhere between white and black hat attackers. Grey hat attackers could notice a vulnerability and report it to the owners of the system if that action coincides with their agenda.

- **(a). White Hat Hackers –** These hackers utilize their programming aptitudes for a good and lawful reason. These hackers may perform network penetration tests in an attempt to compromise networks to discover network vulnerabilities. Security vulnerabilities are then reported to developers to fix them and these hackers can also

work together as a blue team. They always use the limited amount of resources which are ethical and provided by the company, they basically perform pentesting only to check the security of the company from external sources.

- **(b). Gray Hat Hackers –** These hackers carry out violations and do seemingly deceptive things however not for individual addition or to cause harm. These hackers may disclose a vulnerability to the affected organization after having compromised their network and they may exploit it .
- **(c). Black Hat Hackers –** These hackers are unethical criminals who violate network security for personal gain. They misuse vulnerabilities to bargain PC frameworks. theses hackers always exploit the information or any data they got from the unethical pentesting of the network.

2. Organized Hackers: These criminals embody organizations of cyber criminals, hacktivists, terrorists, and state-sponsored hackers. Cyber criminals are typically teams of skilled criminals targeted on control, power, and wealth. These criminals are extremely subtle and organized, and should even give crime as a service. These attackers are usually profoundly prepared and well-funded.

3. Internet stalkers: Internet stalkers are people who maliciously monitor the web activity of their victims to acquire personal data. This type of cyber crime is conducted through the use of social networking platforms and malware, that are able to track an individual's PC activity with little or no detection.

4. Disgruntled Employees: Disgruntled employees become hackers with a particular motive and also commit cyber crimes. It is hard to believe that dissatisfied employees can become such malicious hackers. In the previous time, they had the only option of going on strike against employers. But with the advancement of technology there is increased in work on computers and the automation of processes, it is simple for disgruntled employees to do more damage to their employers and organization by committing cyber crimes. The attacks by such employees brings the entire system down.

1.9 Classification of cybercrimes

It can be classified in to 4 major categories as

1. **Cyber crime against Individual**
2. **Cyber crime Against Property**
3. **Cyber crime Against Organization**
4. **Cyber crime Against Society**

1. **Against Individuals**
    1. **Email spoofing :**
       A spoofed email is one in which e-mail header is forged so that mail appears to originate from one source but actually has been sent from another source
    2. **Spamming :**

Spamming means sending multiple copies of unsolicited mails or mass e-mails such as chain letters.

3. **Cyber Defamation :**
   This occurs when defamation takes place with the help of computers and / or the Internet. E.g. someone publishes defamatory matter about someone on a website or sends e-mails containing defamatory information.

4. **Harassment & :**
   Cyber Stalking Means following the moves of an individual's activity over internet. It can be done with the help of many protocols available such at e-mail, chat rooms, user net groups.

2. **Against Property:**

   1. **Credit Card Fraud** : As the name suggests, this is a fraud that happens by the use of a credit card. This generally happens if someone gets to know the card number or the card gets stolen.

   2. **Intellectual Property crimes :** These include Software piracy: illegal copying of programs, distribution of copies of software.

      1. Copyright infringement:

      2. Trademarks violations:
         Theft of computer source code:

   3. **Internet time theft :**
      the usage of the Internet hours by an unauthorized person which is actually paid by another person.

3. **Against Organisation**

   1. **Unauthorized Accessing of Computer:**
      Accessing the computer/network without permission from the owner. it can be of 2 forms:

      1. <u>Changing/deleting data:</u>
         Unauthorized changing of data.

      2. <u>Computer voyeur:</u>
         The criminal reads or copies confidential or proprietary information, but the data is neither deleted nor changed.

   2. **Denial Of Service:**
      When Internet server is flooded with continuous bogus requests so as to denying legitimate users to use the server or to crash the server.

   3. **Computer contamination / Virus attack :**
      A computer virus is a computer program that can infect other computer

programs by modifying them in such a way as to include a (possibly evolved) copy of it.
Viruses can be file infecting or affecting boot sector of the computer.
Worms, unlike viruses do not need the host to attach themselves to.

4. **Email Bombing :**
   Sending large numbers of mails to the individual or company or mail servers thereby ultimately resulting into crashing.

5. **Salami Attack :**
   When negligible amounts are removed & accumulated in to something larger. These attacks are used for the commission of financial crimes.

6. **Logic Bomb :**
   Its an event dependent programme , as soon as the designated event occurs, it crashes the computer, release a virus or any other harmful possibilities.

7. **Trojan Horse :**
   an unauthorized program which functions from inside what seems to be an authorized program, thereby concealing what it is actually doing.

8. **Data diddling :**
   This kind of an attack involves altering raw data just before it is processed by a computer and then changing it back after the processing is completed.

4. **Against Society**

   1. **Forgery:** currency notes, revenue stamps, mark sheets etc can be forged using computers and high quality scanners and printers.

   2. **Cyber Terrorism:** Use of computer resources to intimidate or coerce others.

   3. **Web Jacking:** Hackers gain access and control over the website of another, even they change the content of website for fulfilling political objective or for money.

1.10 A Global perspective on cyber crimes

Cybercrime has become a global issue due to the rapid development of the internet and computer technology. It poses a significant threat to the world, and here are some of the ways cybercrime impacts the global community:

- **Economic impact**: Cybercrime is expected to cause over $9 trillion in damages worldwide in 2024. If it were a country, cybercrime would be the world's third-largest economy.
- **Supply chain disruption**: Cyber attackers are disrupting critical supply chains.
- **Malware**: In 2021, there were over 1.2 billion malware samples, with about 18 million new samples added each month.
- **Data breaches**: In 2020, the average cost of a data breach was around $3.9 million.
- **Cross-border crimes**: Cybercriminals can easily operate across borders, making it difficult to determine jurisdiction in cyber disputes.

- **Law enforcement challenges**: Cybercrime has created new problems for law enforcement agencies around the world

1.11 Cyber laws

Cyber law, also known as internet law or digital law, signifies the legal regulations and frameworks governing digital activities. It covers a large range of issues, including online communication, e- commerce, digital privacy, and the prevention and prosecution of cybercrimes.

1.11.1 Types of Cyber Law

- **Privacy Laws:**

Privacy laws focus on protecting individuals' personal information from unauthorized access and use. They establish guidelines for the responsible handling of personal data by organizations, ensuring individuals' privacy rights are upheld.

- **Cybercrime Laws:**

Cybercrime laws define and penalize various cybercrimes, ensuring legal consequences for offenders. These laws play a crucial role in deterring individuals from engaging in illegal online activities and provide a legal framework for prosecuting cybercriminals.

- **Intellectual Property Laws:**

Intellectual property laws in the digital domain protect patents, copyrights, and trademarks from unauthorized use. They provide a legal foundation for creators and innovators to protect their digital assets.

- **E-commerce Laws:**

E-commerce laws regulate online business transactions, defining rules for contracts, transactions, and consumer protection. These laws contribute to the establishment of a secure and fair online marketplace.

- **Cyber Defamation Laws:**

Cyber defamation laws address libel and slander in the digital space. They provide legal remedies for individuals or entities whose reputations may be tarnished by false or damaging information circulated online.

- **Cybersecurity Laws:**

Cybersecurity laws establish standards for securing digital systems and data. These laws mandate organizations to implement measures to protect against cyber threats, contributing to the overall resilience of digital infrastructure.

- **Social Media Laws:**

Social media laws address legal issues related to social media platforms, including user rights and content regulations. These laws aim to strike a balance between freedom of expression and the prevention of online abuse or misinformation.

- **Cyber Contracts and E-signature Laws:**

Governing the validity and enforceability of contracts formed online, cyber contracts and e-signature laws provide legal certainty for electronic transactions. They facilitate the growth of online commerce by ensuring the legal recognition of digital agreements.

- **International Cyber Laws:**

With the increasing prevalence of cross-border cybercrimes, international cyber laws address the need for cooperation between nations. These laws facilitate collaboration in investigating and prosecuting cybercriminals operating across borders.

- **Data Breach Notification Laws:**

Mandating organizations to inform individuals and authorities in the event of a data breach of data breach notification laws enhances transparency and accountability. They ensure prompt action in response to security incidents, minimizing the potential impact on individuals and businesses.

1.12 The Indian IT Act

The Information Technology Act, 2000 also Known as an **IT Act** is an act proposed by the Indian Parliament reported on 17th October 2000. This Information Technology Act is based on the United Nations Model law on Electronic Commerce 1996 (UNCITRAL Model) which was suggested by the General Assembly of United Nations by a resolution dated on 30th January, 1997. It is the most important law in India dealing with Cybercrime and E-Commerce.

The Indian cyber laws are governed by the Information Technology Act, penned down back in 2000. The principal impetus of this Act is to offer reliable legal inclusiveness to eCommerce, facilitating registration of real-time records with the Government.
But with the cyber attackers getting sneakier, topped by the human tendency to misuse technology, a series of amendments followed.
The ITA, enacted by the Parliament of India, highlights the grievous punishments and penalties safeguarding the e-governance, e-banking, and e-commerce sectors. Now, the scope of ITA has been enhanced to encompass all the latest communication devices.
The IT Act is the salient one, guiding the entire Indian legislation to govern cybercrimes rigorously:
Section 43 - Applicable to people who damage the computer systems without permission from the owner. The owner can fully claim compensation for the entire damage in such cases.
Section 66 - Applicable in case a person is found to dishonestly or fraudulently committing any act referred to in section 43. The imprisonment term in such instances can mount up to three years or a fine of up to Rs. 5 lakh.
Section 66B - Incorporates the punishments for fraudulently receiving stolen communication devices or computers, which confirms a probable three years imprisonment. This term can also be topped by Rs. 1 lakh fine, depending upon the severity.
Section 66C - This section scrutinizes the identity thefts related to imposter digital signatures, hacking passwords, or other distinctive identification features. If proven guilty, imprisonment of three years might also be backed by Rs.1 lakh fine.
Section 66 D - This section was inserted on-demand, focusing on punishing cheaters doing

impersonation using computer resources.

The main objective of this act is to carry lawful and trustworthy electronic, digital and online transactions and alleviate or reduce cybercrimes. The IT Act has 13 chapters and 94 sections. The last four sections that starts from 'section 91 – section 94', deals with the revisions to the Indian Penal Code 1860. **The IT Act, 2000 has two schedules:**

- **First Schedule –**
  Deals with documents to which the Act shall not apply.
- **Second Schedule –**
  Deals with electronic signature or electronic authentication method.

The offences and the punishments in IT Act 2000 :
The offences and the punishments that falls under the IT Act, 2000 are as follows :-

1. Tampering with the computer source documents.
2. Directions of Controller to a subscriber to extend facilities to decrypt information.
3. Publishing of information which is obscene in electronic form.
4. Penalty for breach of confidentiality and privacy.
5. Hacking for malicious purposes.
6. Penalty for publishing Digital Signature Certificate false in certain particulars.
7. Penalty for misrepresentation.
8. Confiscation.
9. Power to investigate offences.
10. Protected System.
11. Penalties for confiscation not to interfere with other punishments.
12. Act to apply for offence or contravention committed outside India.
13. Publication for fraud purposes.
14. Power of Controller to give directions.

1.13 Cybercrime and punishment

In order to control the rise in cybercrime cases, specific punishments are imposed under the India Penal Code, 1860 and the Information Technology Act 2000. Below are the Sections that identify the punishments imposed on an individual committing cybercrime.

Under The Indian Penal Code

- **Section 292**: This Section deals with the sale of obscene materials either in the form of a book, paper, drawing, writing, pamphlet, painting, etc., or sexually explicit acts

harming the surroundings. An individual or a group involved in such an offence is punished with imprisonment and a fine. On a first conviction, the punishment is imprisonment for two years and Rs. 2000 fine whereas on a second or subsequent conviction, the punishment is imprisonment for a term that may extend to five years and Rs. 5,000 fine.

- **Section 354C**: It deals with the offence of voyeurism, where an individual watches or captures, or publicizes the image of a woman engaged in a private Act without her consent. Under the provisions of this Section of IPC, such an offender or criminal is punished with imprisonment of 1 to 3 years and 3 to 7 years for first-time and second-time offenders respectively.
- **Section 354D**: This section deals with stalking both physical and cyberstalking. As per this Section, "Any man who follows a woman and contacts, or attempts to contact such woman to foster personal interaction repeatedly despite a clear indication of disinterest by such woman or monitors the use by a woman of the interest, email or any other form of electronic communication, commits the offence of stalking." An offender will be punished with imprisonment that may extend to three years for the first offender and five years for the second offender.
- **Section 379**: If a person commits theft either electronically or physically, he or she will be punished under the provisions of this Section. It states that "whoever commits theft shall be punished with imprisonment of either description for a term which may extend to three years or with fine, or with both."
- **Section 411**: If a person receives any stolen property such as a computer, mobile phone, or data then he or she will be punished for three years or fine or both.
- **Section 419**: This Section deals with fraud such as email phishing or committing the crime of password theft for impersonating and collecting data for personal benefit. According to this Section, "Whoever cheats by personation shall be punished with imprisonment of either description for a term which may extend to three years, or with fine, or with both."
- **Section 420:** It also deals with fraud cases especially 'cheating and dishonestly inducing delivery of property'. Whoever dishonestly induces one's property, "the person deceived to deliver any property to any person r to make or alter or destroy the whole or any part of a valuable security… and which is capable of being converted into a valuable security, shall be punished with imprisonment of either description for a term which may extend to seven years, and shall also be liable to fine."
- **Section 465**: The punishment for forgery, email spoofing, preparation of false documents, etc., are dealt with in Section 465 of the IPC. It states that anyone who commits forgery should be punished with imprisonment extending to two years, a fine, or both.
- **Section 468**: This Section deals with the forgery of documents or electronic records for committing other serious crimes such as cheating. As per the provisions of this Section, whoever commits such a crime shall be punished with imprisonment which may extend to seven years with a fine. It is a non-bailable offence.
- **Section 469**: According to this Section, forgery for the purpose of harming reputation is a punishable offence. Section 469 states that "Whoever commits forgery, 1[intending that the document or electronic record forged] shall harm the reputation of any party, or knowing that it is likely to be used for that purpose, shall be punished with imprisonment of either description for a term which may extend to three years, and shall also be liable to fine."
- **Section 500**: It states that "Whoever defames another shall be punished with simple imprisonment for a term which may extend to two years, or with fine, or with both."

This means that any individual who sends abusive messages or defamatory content via email or any other electronic form is dealt with as per the provisions of Section 500 of the IPC.

- **Section 504**: If anyone insults, tries to provoke, or threatens another person with the motive of affecting their peace via any electronic form of communication will be attracted by Section 504 of the IPC. As per its provisions, an individual involved in such an offence is punished with imprisonment which may extend to two years or a fine or both.
- **Section 506**: This Section deals with the 'punishment for criminal intimidation'. If an individual tries to intimidate another individual shall be punished with imprisonment which may extend to two years or a fine or both. This criminal intimidation can either be physical or through electronic means.
- **Section 509**: It states that "Whoever intending to insult the modesty of any woman, utters any word, makes any sound or gesture, or exhibits any object, intending that such word or sound shall be heard, or that such gesture or object shall be seen, by such woman, or intrudes upon the privacy of such woman, shall be punished with simple imprisonment for a term which may extend to one year, or with fine, or with both."

Under the Information Technology Act

- **Section 43 (a-h)**: It covers 8 instances (a-h) where "If any person without the permission of the owner or any other person who is in charge of a computer, computer system or computer network,"
- **Section 65**: 'Tampering with computer source documents' is an offence that is punishable under Section 65 of the Information Technology Act. It states that "Whoever knowingly or intentionally conceals, destroys or alters or intentionally or knowingly causes another to conceal, destroy, or alter any computer source code used for a computer, computer programme, computer system, or computer network when the computer source code is required to be kept or maintained by law for the time being in force, shall be punishable with imprisonment up to three years, or with fine which may extend up to two lakh rupees, or with both".
- **Section 66 (A-F)**: This Section deals with punishments for computer-related offences such as sending offensive messages, receiving stolen computer resources, identity theft, cheating by impersonation, violation of privacy, and cyber-terrorism, punishments may extend to three years imprisonment or a fine of up to 5 lakhs, or both.
- **Section 67 (A-B)**: This Section of the Information Technology Act deals with the punishments related to the publishing or transmitting of obscene material containing sexually explicit act, etc., in an electronic format. The punishment on the first conviction is imprisonment which may extend to three years and with a fine extending to 5 lakh rupees. The punishment on the second conviction is imprisonment which may extend to five years and with a fine extending to 10 lakh rupees.